ETH
Eidgenössische Technische Hochschule Zürich
Swiss Federal Institute of Technology Zurich

Bachelor's Thesis Proposal

Model transformations for privacy by design

Supervisor: Dr. Srđan Krstić, Hoang Nguyen
Professor: Prof. David Basin

1 Prerequisites

Familiarity with databases, SQL, web development and model-driven development. [1]

2 Motivation

Data protection regulations in many countries, such as the GDPR [2], require IT systems to comply with various privacy requirements. These requirements are particularly challenging to implement as system developers must address them consistently and in a cross-cutting manner. Moreover, without a formal connection between a system's privacy policy and its implementation, arguing for its correctness and evolving it over time becomes extremely difficult.

Previously, Basin et al. [1] have proposed a model-driven security (MDS) approach for building secure-by-design systems. In addition to the application, they model security requirements expressed as fine-grained access control (FGAC) permissions. The idea is that software engineer first creates a design model in a design modeling language (e.g., a UML class diagram) and then a security engineer creates a security model in a security modeling language. Using model transformations, a secure-by-design implementation is then obtained from the two models.

Recently, Krstić et.al. [5] extended MDS with the support for privacy by proposing a new model that captures two common privacy requirements: *purpose-limitation* and *consent*. Given such a model two model transformations generate compliant system implementation for in C# and Python, respectively. Finally, as a proof of concept, they have used these model transformations to implement three case study web applications.

3 Objective

The model transformations mentioned above are implemented in Python directly and support only a fragment of the design modeling elements. In this thesis, we would like to implement model transformations for privacy by design using the state-of-the-art model transformation tools. The main goal is to replace the current model transformation prototypes with a new toolkit that implements the approach following model-driven development best practices. It would also target a larger and more complete set of model elements defined by the appropriate UML metamodels. To evaluate whether this toolkit is actually better, in terms of usability, scalability and performance, we plan to compare it with the existing prototypes under the three case studies in [5].

[1] E.g., see the course on Security Engineering: `https://infsec.ethz.ch/education/as2022/seceng.html`

4 Tasks

1. Understand the proposed model-driven security and privacy approach in [5].
2. Review model-driven development techniques, existing model transformation tools (e.g., ATL [3], Acceleo [4]) and their capabilities and trade-offs.
3. Define (or extend some existing) metamodels for data, security and privacy models as in [5].
4. Define (or extend an existing) concrete syntax for these models.
5. Using the selected model transformation tool(s), implement model-to-model transformation from the three aforementioned models to (extended) data model.
6. For a selected programming language, i.e. `Python` or `C#`, implement model-to-code transformations from the extended data, security and privacy model to application artifacts.
7. Iteratively add modeling elements to the data model's and adjust steps 5 and 6 accordingly. Possible elements to support: association classes, n-ary associations, all collection types, and others defined by the supervisors.
8. (Optional) Extend the approach to support activity diagrams.
9. (Optional) Extend the approach to generate code in other programming languages (e.g., `Python` or `C#`).
10. Develop one of the case study applications from [5] using the new transformation tool, compare it to existing prototype in terms of conciseness and performance.

5 Deliverables

The following deliverables are due at the end of the project:

Final report The final report should consist of an introduction; a theoretical background section; one or more sections describing the modeling, implementation and evaluation; and a conclusion. The report may be written in English or German.

Source code Complete development including easily reproducible evaluation.

Presentation At the end of the project, a 20 minute presentation must be given in an InfSec group seminar. It should give an overview and discuss the most important highlights of the work.

References

[1] David Basin, Manuel Clavel, Marina Egea, Miguel Angel García de Dios, and Carolina Dania. A Model-Driven Methodology for Developing Secure Data-Management Applications. *IEEE Trans. Software Eng.*, 40(4):324–337, 2014.

[2] European Parliament and Council. Regulation (EU) 2016/679, 2016. `https://eur-lex.europa.eu/eli/reg/2016/679/oj`.

[3] Eclipse Foundation. ATL Transformation Language. `https://www.eclipse.org/atl/`.

[4] Eclipse Foundation. Eclipse acceleo. `https://www.eclipse.org/acceleo/`.

[5] Srdan Krstic, Hoang Nguyen, and David A. Basin. Model-driven privacy. *Proc. Priv. Enhancing Technol.*, 2024(1):314–329, 2024.